Teoría · Cifrado simétrico

AES, modos de operación y cifrado autenticado

Ana María Arias · Allyson Sequeira · Julixa Solano

ITI-922 Seguridad de TI II · UTN Sede San Carlos

No basta un algoritmo fuerte: el modo de operación decide

ECB

Filtra patrones del texto original

CBC · CTR

Ocultan patrones, pero no detectan alteraciones

GCM

Cifra y autentica al mismo tiempo

Cifrado simétrico: una sola llave compartida



Ambos usan la misma llave secreta para cifrar y descifrar

Rápido

Ideal para grandes volúmenes de datos

Problema: distribuir la llave

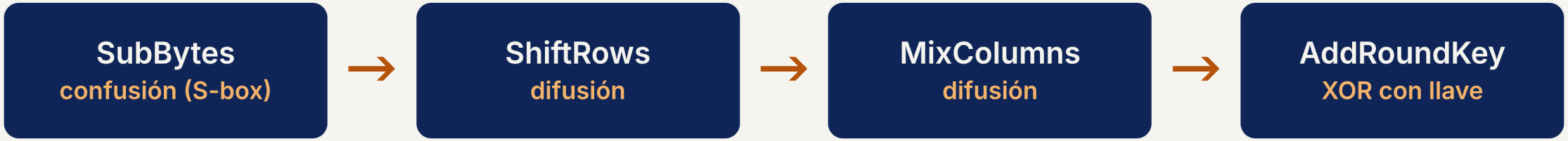
n usuarios necesitan n(n−1)/2 llaves: 1.000 usuarios = 499.500

Solución: cifrado híbrido

Llave pública acuerda la llave de sesión; luego se cifra con AES (así funciona TLS 1.3)

AES: red de sustitución-permutación

Bloque de 16 bytes en una matriz 4×4 (el estado). Cada ronda aplica:



La ronda final omite MixColumns. El descifrado aplica lo inverso en orden inverso.

Variante	Bloque	Llave	Rondas
AES-128	128 bits	128 bits	10
AES-192	128 bits	192 bits	12
AES-256	128 bits	256 bits	14

Modos de operación

Un cifrador de bloque solo conoce un bloque; el modo define cómo cifrar mensajes largos.

Modo	Oculta patrones	Paralelizable	Autentica	IV / nonce
ECB	No	Sí	No	No usa
CBC	Sí	Solo descifrado	No	IV impredecible
CTR	Sí	Sí	No	Nonce único
GCM	Sí	Sí	Sí (AEAD)	Nonce nunca repetido

Solo GCM detecta que alguien modificó los datos.

Cifrado autenticado (AEAD)



Al descifrar

Se recalcula la etiqueta. Si no coincide, se rechaza y no se entrega texto plano.

Regla del nonce

Repetirlo con la misma llave expone C1 ⊕ C2 = P1 ⊕ P2 y en GCM rompe la autenticidad.

Ideas para llevarse

1. El cifrado simétrico es rápido, pero exige distribuir la llave de forma segura
2. AES cifra bloques de 128 bits con llaves de 128, 192 o 256 bits
3. El modo de operación define la seguridad real del mensaje
4. Con GCM se cifra y se autentica; el nonce nunca se repite

Caso real: Adobe (2013)

Contraseñas iguales → **3DES en modo ECB** → **Cifrados idénticos**

Qué pasó

Una filtración expuso millones de registros de usuarios

Por qué falló

ECB deja ver repetidos, y las pistas en texto plano ayudaron a deducir contraseñas

Qué se aprende

Las contraseñas se guardan con hash y sal, no con cifrado reversible, y nunca con ECB